Ce qui circule en clair

Auteurs : NGUEGNI ONGOLO Antoine Depadoux et NKODA Xavier.
Objet : justifier la sécurisation du siège et de l'agence de Douala à partir de preuves de laboratoire.

1. Résumé pour la direction

Le laboratoire CamTrust a satisfait les six contrôles réseau A.7 lors des essais du 25 octobre.

HTTP, FTP et Telnet exposent des identifiants ; SNMPv2c révèle sa communauté et l'inventaire.

HTTPS et SSH rendent les données applicatives illisibles dans les captures comparées.

La migration Telnet vers SSH est effective ; la communauté SNMP temporaire a été supprimée.

La priorité est de fermer les accès en clair, renouveler les secrets et déployer SFTP et SNMPv3.

2. Périmètre et autorisation

Autorisation : travaux réalisés à la demande du proprietaire de l'environnement, dans son labo EVE-NG **TP1**. Aucun scan ni capture sur un réseau tiers. Les captures datent du **25 octobre 2026** ; cette fiche est analysee et mise en forme le **26 octobre**. Le poste graphique de navigation Internet est distinct et exclu des preuves du TP.

Huit noeuds : R-SIEGE (IOSv), SW-SIEGE (IOSvL2), R-DLA (CHR 7), R-FAI (VyOS), deux VPCS et deux Ubuntu 24.04. LAN siège 10.10.10.0/24 ; agence 10.20.10.0/24 ; liaison privee 172.16.12.0/30 ; FAI 198.51.100.0/30 ; serveur simulé 203.0.113.10. Outils : consoles, tcpdump, Wireshark/TShark 4.6.5, dig, curl, telnet, OpenSSH et snmpwalk.

Contrôle A.7 exécuté	Résultat conserve dans preuves/
DHCP PC-SIEGE	10.10.10.102/24 ; GW 10.10.10.1 ; DNS 203.0.113.10
DHCP PC-DLA	10.20.10.199/24, dans la plage .100-.200
Douala vers siège	5 réponses au ping 10.10.10.1
CLIENT-LINUX vers serveur	3 paquets reçus sur 3 vers 203.0.113.10
DNS	www.camtrust.lab = 203.0.113.10
HTTP	Page Apache reçue par CLIENT-LINUX

Points de capture : SW-SIEGE - R-SIEGE pour ARP, DHCP, Telnet/SSH et SNMP ; R-FAI - SRV-INTERNET pour DNS, TCP, HTTP/HTTPS et FTP. Les adresses dites Internet sont des plages de documentation ; elles ne prouvent aucun accès au réseau reel.

État observe : les six tests A.7 ont reussi le 25 octobre. Le nouvel etat de fonctionnement après l'interruption de stockage n'est pas présenté comme retesté. Les exports et les preuves enregistrés restent disponibles.

3. Constats : synthèse C.5

Service	Protocole utilisé	Visible en clair	Remplacement sûr	Effort entreprise
Espace agents	HTTP / TCP 80	URL, contenu, utilisateur et secret Basic décodé	HTTPS / TLS, certificat valide	4-8 h ; certificat selon PKI
Fichiers	FTP / TCP 21	USER, PASS et commandes ; contenu non protégé par FTP	SFTP ou FTPS	1-2 jours ; migration des clients
Administration	Telnet / TCP 23	Utilisateur, mot de passe et commandes	SSH v2, algorithmes modernes	2-4 h ; mise à jour IOS si besoin
Supervision	SNMP v2c / UDP 161	Communaute, nom et version de l'équipement	SNMPv3 authPriv	0,5-1 jour ; outil compatible

Une vue par ligne du tableau : relevés d'analyse TShark issus des captures reelles, affichés puis captures à l'écran. Ce sont des **vues de synthèse**, pas des captures de l'interface Wireshark. Les secrets sont masques ; les PCAPNG expurgés permettent de controler les champs et les trames.



Figure 1 - Web : HTTP / HTTPS

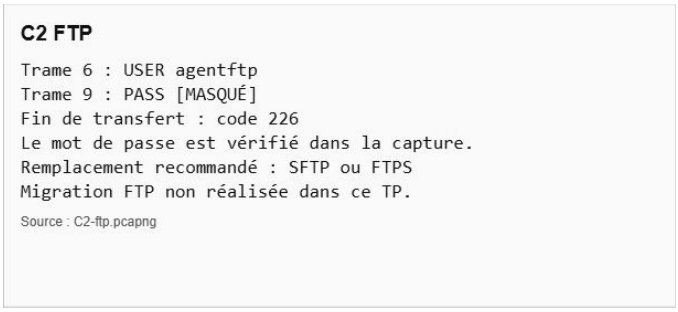


Figure 2 - FTP : USER / PASS



Figure 3 - Telnet / SSH

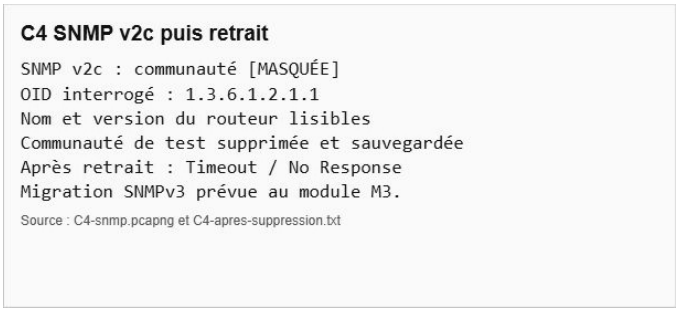


Figure 4 - SNMP : exposition / retrait

HTTP : Basic est un encodage Base64, pas un chiffrement. Le secret a été retrouve et vérifié dans l'original. En TLS, seuls la négociation, les métadonnées réseau et le SNI restent visibles ici ; le contenu applicatif est chiffré. Le serveur a répondu 200 en HTTP et HTTPS.

Limites : HTTPS utilisé le certificat auto-signé du labo (curl -k seulement pour ce test). FTP n'a pas été migre. Le retrait SNMPv2c ne constitue pas une migration SNMPv3. Ces corrections restent au plan d'action.

Analyse des captures et enjeux entreprise

Les captures B.1 a B.4 sont conservees sans modification. Les filtres ci-dessous sont des filtres d'affichage Wireshark. B1 contient aussi l'ICMP declencheur ; B4 conserve les deux ports afin de comparer service ouvert et ferme.

Exercice / filtre	Valeurs réellement relevees
B.1 : arp	Requete vers ff:ff:ff:ff:ff:ff ; réponse de 50:00:00:09:00:00 vers le poste ; EtherType 0x0806.
B.2 : dhcp	RELEASE puis DORA, DISCOVER retransmis. UDP 68 vers 67, retour 67 vers 68. Offre : /24 ; GW 10.10.10.1 ; DNS 203.0.113.10 ; domaine camtrust.lab ; bail 86 400 s.
B.3 : dns	Requete A en UDP : ID 0xab53, port client 51517. En TCP : ID 0x76a1, port client 41799. Reponse 203.0.113.10 ; TTL 300 s.
B.4 : tcp.port == 80 || tcp.port == 8080	Trames 1-3 : SYN, SYN-ACK, ACK. HTTP 200 puis FIN-ACK (22-23). Port 80 : 24 trames, environ 12 kB et 0,1002 s. Port 8080 : SYN (25), RST-ACK (26).

Reponses aux quatre questions entreprise

B.1 - Retrouver le port d'un poste - Executer show ip arp 10.10.10.157 sur le routeur, puis show mac address-table address <MAC> sur le switch. Si la MAC se trouve sur un lien inter-switch, suivre ce lien jusqu'au port d'accès. Verifier la fraîcheur de l'entrée ARP et le plan de câblage : une association absente ou usurpée ne suffit pas a identifier un poste.

B.2 - Bloquer un serveur DHCP pirate - Activer DHCP snooping sur les VLAN concernes. Declarer de confiance uniquement les ports menant aux serveurs DHCP légitimes, ici la liaison vers R-SIEGE ; les ports des postes restent non fiables. Un OFFER est une réponse de protocole, pas une preuve d'identité du serveur.

B.3 - Visibilite DNS et resolveur interne - Le DNS classique exposé les noms demandes à un tiers sur le chemin, sans reveler nécessairement une page précise ni prouver qu'une visite a abouti. Un resolveur interne applique une politique commune et conserve des traces utiles à l'investigation. Limiter l'accès et la rétention des journaux ; DNSSEC ne chiffré pas les requêtes.

B.4 - RST ou silence à la frontiere - Un RST confirme qu'un hote ou un filtre repond et facilite la reconnaissance. Pour les connexions entrantes non autorisées, un refus par défaut silencieux peut réduire cette indication, sans remplacer la reduction de la surface exposée. Journaliser les refus utiles avec limitation de débit pour detecter les scans sans saturer les traces.

4. Plan d'action et contrôles après correction

Les efforts ci-dessous sont des estimations pour un petit périmètre, hors attente de changement. Ils ne sont pas des temps mesurés pendant le TP. P1 : identifiants exposés et accès d'administration ; P2 : supervision et traitement durable de la dette technique.

Priorité / service	Correction et critère de recette	Effort / achat	Référence au cours
P1 - Web	Certificat valide, HTTPS obligatoire, redirection ou fermeture HTTP ; verifier chaine et nom du certificat. Renouveler les secrets exposés.	4-8 h ; pas d'achat impose si PKI interne adaptée	TP0.1 C.1 ; module d'approfondissement non fourni
P1 - Fichiers	Migrer vers SFTP (ou FTPS selon les clients), revoir comptes/droits et couper FTP ; valider un transfert et l'absence de PASS en clair.	1-2 jours ; outils existants à vérifier	TP0.1 C.2 ; module d'approfondissement non fourni
P1 - Routeur	Conserver SSH v2 et le refus Telnet. Mettre à jour IOS pour les algorithmes modernes, renouveler secret et clés ; retester sans option de compatibilite.	2-4 h ; licence/support seulement si requis par la mise à jour	TP0.1 C.3 ; module d'approfondissement non fourni
P2 - Supervision	Deployer SNMPv3 authPriv, limiter les sources de supervision et supprimer v2c ; verifier authentification, chiffrement et refus v2c.	0,5-1 jour ; achat seulement si supervision incompatible	M3 : SNMPv3, explicitement cite par le sujet

Les références C.1-C.3 sont vérifiables dans l'énoncé. Aucun numero de module supplémentaire n'est invente : le programme détaillé correspondant n'a pas été fourni.

Ce qui a effectivement été vérifié

Avant / après	Preuve et limité
HTTP / HTTPS	C1-http et C1-https : secret lisible après decodage Basic dans l'original ; TLS Application Data dans la comparaison. Codes 200 cote client.
Telnet / SSH	C3-telnet : identifiants et show version visibles dans l'original. C3-ssh : échange de clés puis paquets chiffrés ; show version exécuté. Après migration, port Telnet : Connection refused.
SNMP v2c / retrait	C4-snmp : communauté et inventaire lisibles. Après suppression : Timeout: No Response. Pas de preuve SNMPv3, car non déployé.

Point technique : cet IOSv ancien exige des options ssh-rsa / diffie-hellman-group14-sha1 pour le seul test OpenSSH. Aucun reglage global du client n'a été affaibli. Le chiffrement observe ne rend pas ces algorithmes anciens acceptables en production.

État final enregistré : transport VTY limité a SSH ; communauté de test retirée ; configurations sauvegardées. HTTP et FTP restent disponibles uniquement dans le labo isole pour les exercices.

5. Annexes : configurations finales

Les exports complets de **R-SIEGE.cfg**, **R-DLA.rsc** et **R-FAI-config.boot** sont integres aux pieces jointes de ce PDF. Les extraits ci-dessous couvrent adressage, DHCP, routage et accès final. Les secrets et empreintes d'authentification sont expurgés dans les exports partages ; les redéfinir avant toute restauration.

A. R-SIEGE - IOSv

```
hostname R-SIEGE
ip domain name camtrust.lab
ip dhcp excluded-address
  10.10.10.1 10.10.10.99
ip dhcp pool LAN-SIEGE
 network 10.10.10.0 255.255.255.0
 default-router 10.10.10.1
 dns-server 203.0.113.10
 domain-name camtrust.lab
interface GigabitEthernet0/0
 ip address 10.10.10.1
   255.255.255.0
interface GigabitEthernet0/1
 ip address 198.51.100.2
   255.255.255.252
interface GigabitEthernet0/2
 ip address 172.16.12.1
   255.255.255.252
ip route 0.0.0.0 0.0.0.0
  198.51.100.1
ip route 10.20.10.0 255.255.255.0
  172.16.12.2
ip ssh version 2
line vty 0 4
 login local
 transport input ssh
! Compte admin : secret expurge
! Aucune communaute SNMP de test
```

Les retours à la ligne dans les commandes longues sont uniquement typographiques. Les valeurs VyOS sont une lecture compacte de l'export. Pour restaurer, utiliser l'export texte complet et définir les accès.

B. R-DLA - RouterOS 7

```
/system identity set name=R-DLA
/ip pool add name=pool-dla
 ranges=10.20.10.100-10.20.10.200
/ip address add address=172.16.12.2/30
 interface=ether1 network=172.16.12.0
/ip address add address=10.20.10.1/24
 interface=ether2 network=10.20.10.0
/ip dhcp-server add
 address-pool=pool-dla
 interface=ether2 name=dhcp-dla
/ip dhcp-server network add
 address=10.20.10.0/24
 dns-server=203.0.113.10
 domain=camtrust.lab gateway=10.20.10.1
/ip route add dst-address=0.0.0.0/0
 gateway=172.16.12.1
```

C. R-FAI - VyOS

```
interfaces ethernet eth0
 address 198.51.100.1/30
interfaces ethernet eth1
 address 203.0.113.1/24
protocols static route 10.0.0.0/8
 next-hop 198.51.100.2
protocols static route 172.16.0.0/12
 next-hop 198.51.100.2
system host-name R-FAI
! Identifiant vyos : secret expurge
```

Intégrité et traçabilité. Le manifeste SHA256-ANNEXES.txt couvre les pieces jointes ; traçabilité-captures.json relie les captures expurgées a leurs originaux locaux. Les copies C1 HTTP, C2 FTP, C3 Telnet et C4 SNMP sont expurgées à longueur constante, avec sommes de contrôle recalculées. Ni les dates, ni les adresses, ni les resultats applicatifs n'ont été inventes.

Document autonome. Les exports, les dix PCAPNG et les journaux sont integres comme pieces jointes (panneau Pieces jointes d'un lecteur PDF compatible). Cette presentation reprend les preuves du laboratoire commun, sans constituer une nouvelle campagne d'essais. Depot d'accompagnement : github.com/Nguegni/Nguegni_tp1. Cette fiche ne constitue pas une remise Classroom.